Tiers for Fears

How Every Attacker Wants to Rule Your World

Jared Atkinson
CTO

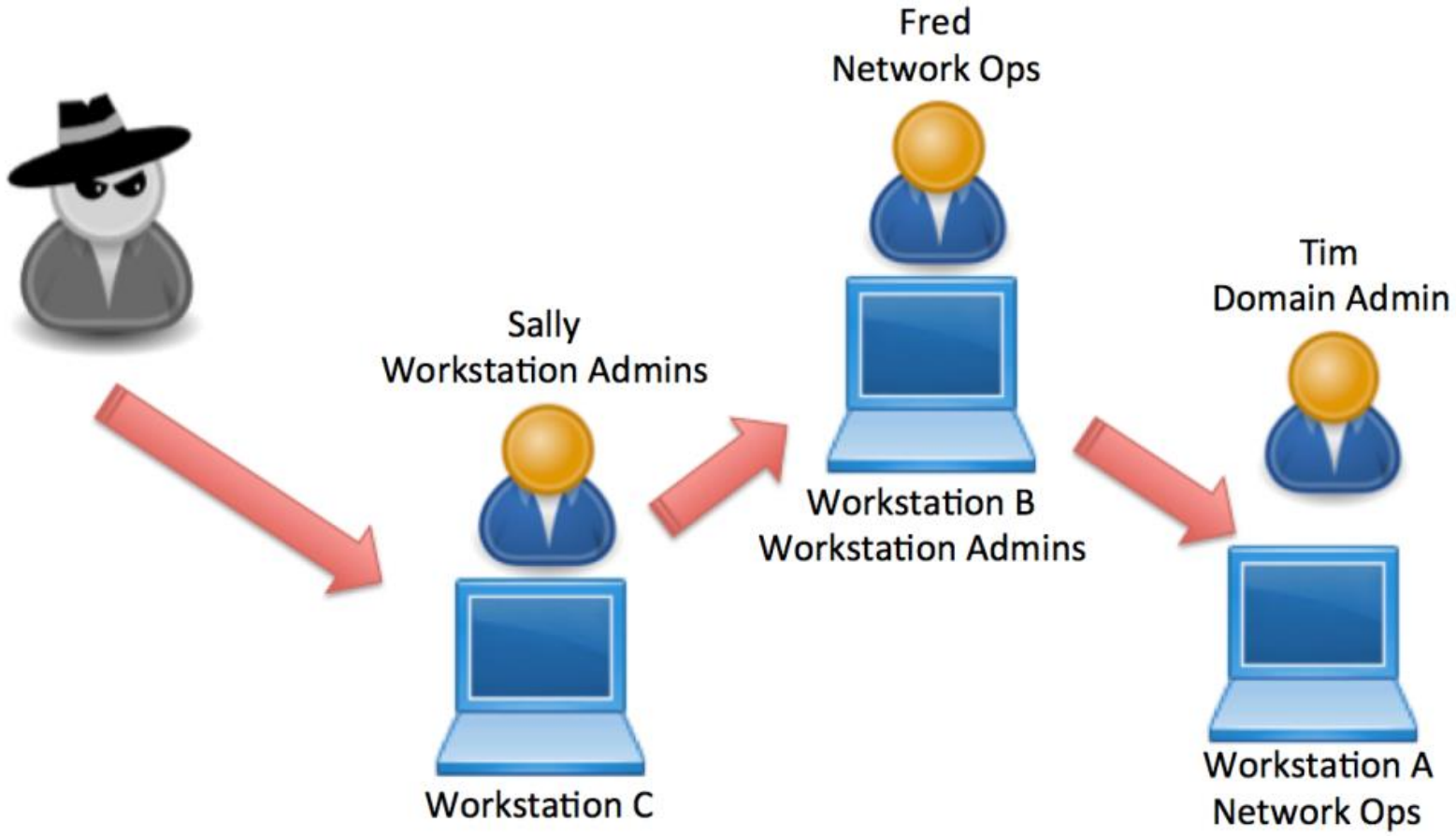
Jason Wolfe
Manager, Product Marketing

The Birth of BloodHound

Defenders think in lists; Attackers think in graphs

Derivative Local Admin

An early lesson in effective control: administrative outcomes often emerge from indirect privilege



https://sixdub.medium.com/derivative-local-admin-cdd09445aac8

The Evolution of a BloodHound

To Stop an Attacker, You Must Think Like an Attacker

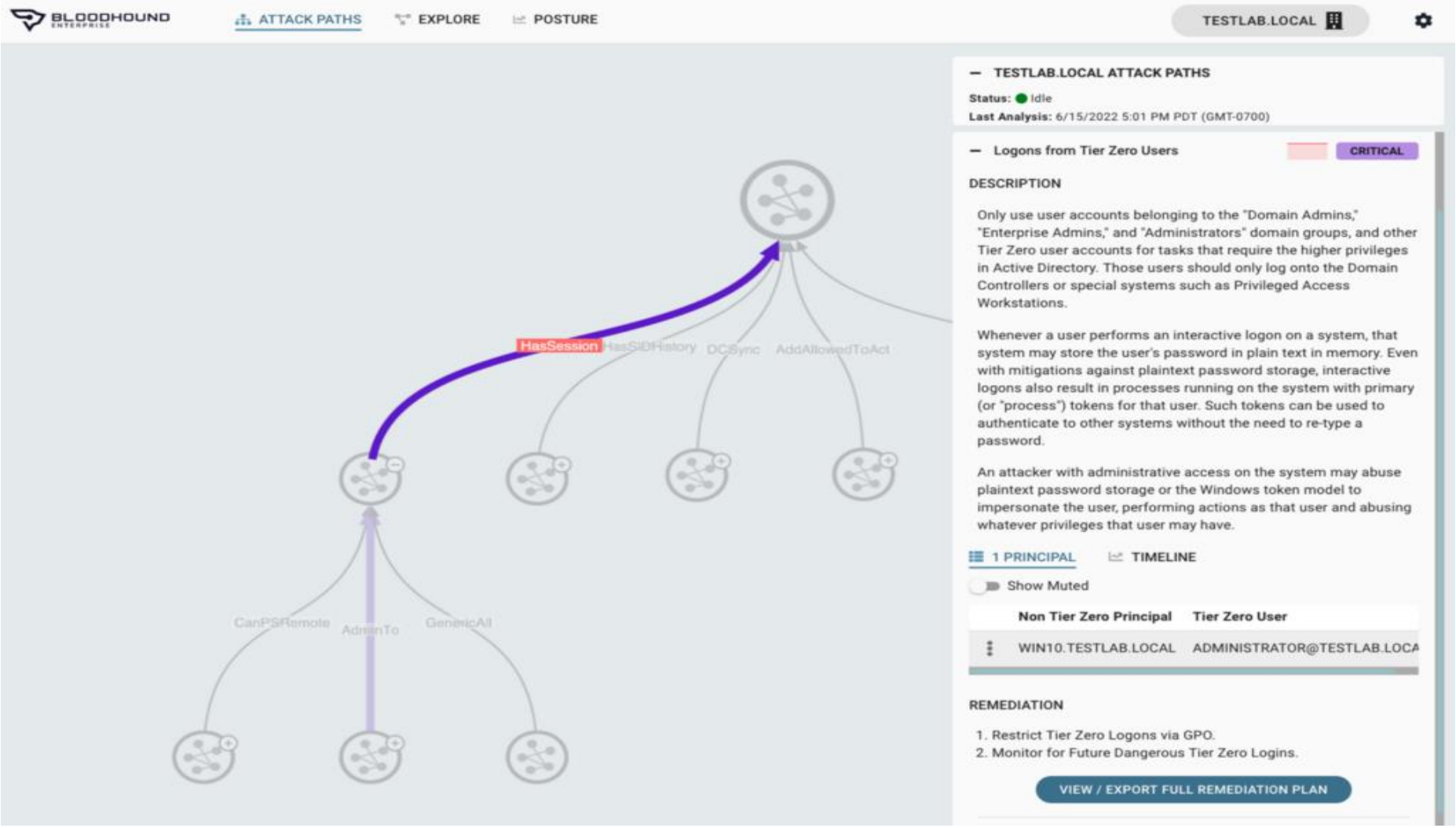
BloodHound Enterprise reflects the vision that SpecterOps has always had for identity Attack Path Management (APM):

- A unified, cross-environment platform protecting critical assets such as sensitive data, critical business applications, code repositories, and more, from identity attack paths
- Visibility, protection, and remediation guidance across the full identity and infrastructure ecosystem, while
- Extensibility to map threats across new environments as the landscape changes

BLOODHOUND
ENTERPRISE

Tier Zero (T0) Isolation

The same principle scaled upward: understanding and severing indirect control paths



Thinking Beyond Tier Zero

The same control-path logic applies outside identity infrastructure to any boundary that concentrates trust

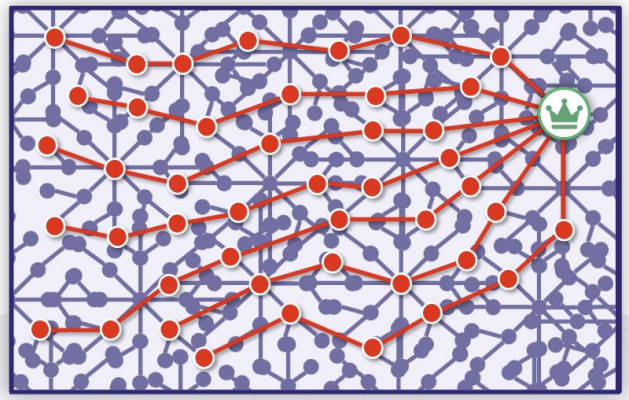
- BloodHound started by asking a simple question: can an attacker reach Tier Zero?
- Tier Zero was powerful because it was one of the few relatively stable and recognizable security boundaries across environments
- It gave defenders a practical proxy for catastrophic downstream impact
- The early revelation for many customers was that Tier Zero was effectively exposed from almost anywhere

Revisiting the Highway Analogy

Finding An Attack Path is Guaranteed

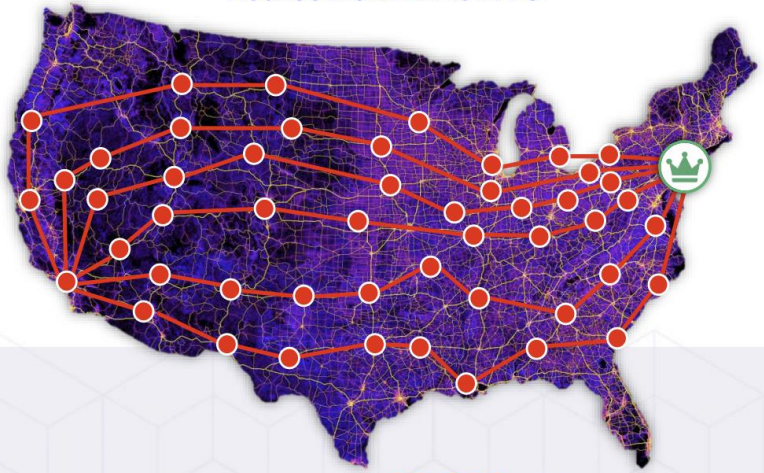
HUNDREDS of MILLIONS
of possible paths can be taken

A single identity provider



130,000 objects
3.5 million abusable relationships

Routes from LA to NYC



20,000 cities
5 million roads

Attackers Don’t Just Take Highways

Tier Zero is an interstate, not the destination

Attackers want sensitive databases, intellectual property, payment platforms, and customer-facing applications. These systems generate revenue, ensure compliance, and define a competitive edge. Tier Zero provides the vantage point to spot these assets.

Highways and Backroads

A back road might be the best option

Tier Zero = The Interstate

- Fastest route
  - Domain controllers, global admins, etc.
- Complete system compromise
- Typically, significantly exposed
- Means to reach a destination

Privilege Zone = The Destination

- Reachable by backroads and alleyways
- Longer routes, but less visibility
- What attackers actually came for
- Widely dispersed throughout environment
- Access tends to be more widely available and less measured

The Business Does Not Think In Terms of T0

It thinks in terms of the systems, data, and functions that keep the mission running

- Tier Zero still matters A LOT
  - Each environment has its own T0 Zone
  - Platforms/Environments exist in a hierarchical relationship to one another
    - AD -> Entra -> Okta -> GitHub
- However, this is not how the business understands risk
  - They are thinking in terms of disruption of certain systems or processes
    - MGM Resorts – hospitality operations disrupted
    - Maersk – global logistics disruption
    - Colonial Pipeline – operations halted
- Therefore, we must connect attack paths to those outcomes
  - Focus on uncovering information systems that support critical business processes
  - Translate mission into concrete technical boundary

The business does not care whether the attacker reached Tier Zero.
It cares whether shipping stops, fuel stops flowing, or reservations and hotel operations break.

Mission Systems, Not Administrative Abstractions

Tier Zero matters because it is upstream of business impact, but the business cares about the impact itself.

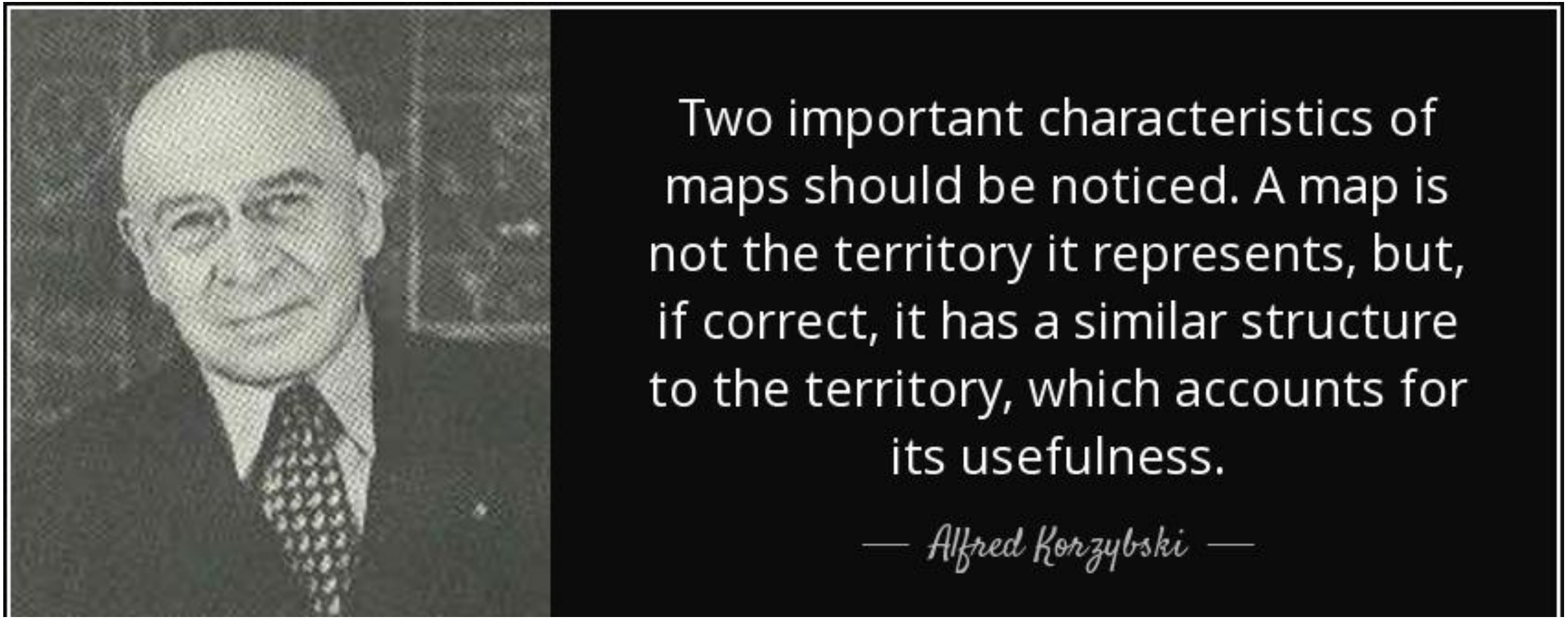
- Air Mobility Command has four primary mission sets:
  - Airlift
  - Air refueling
  - Aeromedical evacuation
  - Global Air Mobility Support System
- Identify the systems that provide the information technology backbone to these mission sets.
  - Define the boundary
  - Identify pathways from outside mission systems into mission systems

AIR MOBILITY COMMAND

AMC delivers the **Right Effects**,
to the **Right Place**, at the **Right Time!**

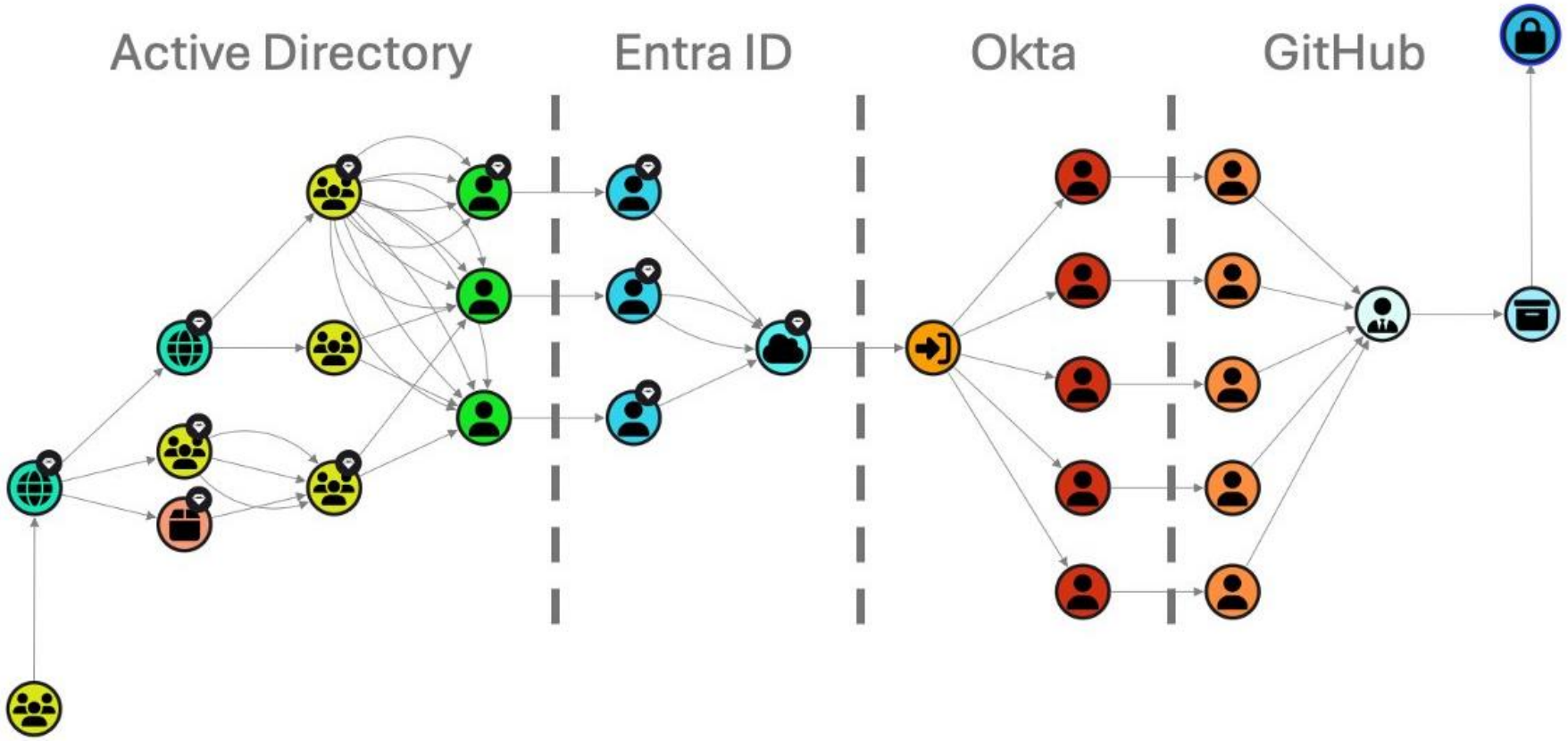
https://www.amc.af.mil/

The Map is Not the Territory



Attack Paths Don’t End at Platform Boundaries

The modern attack surface goes where identities go



Protecting a business system often means protecting the systems that govern it.

Finite Resources, Infinite Terrain

As the map expands and footholds get cheaper, defenders must prioritize what matters most

The environment keeps expanding

- More platforms
- More vulnerabilities
- More identities
- More dependencies
- More attack paths

Defensive resources do not

- Finite people
- Finite time
- Finite attention
- Finite budget

So, the strategy must change

- Assume footholds will happen
- Identify key terrain
- Reduce what arbitrary compromise can still reach

We are not choosing what to ignore.

We are choosing where finite defensive investment has the highest payoff.

Understanding the Initial Foothold

Asking the right questions before an attack starts

Useful, but insufficient questions

- Did the laptop contain sensitive information?
- Was the server internet-facing?
- Was the application business-critical?
- Was the vulnerability CVSS critical?

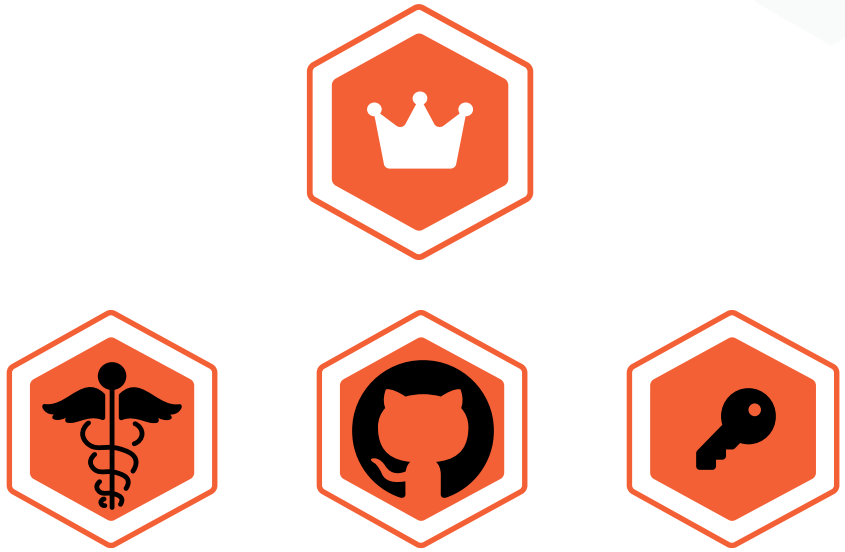
More important questions

- ✓ What identities are present on the host?
- ✓ What sessions and tokens are cached?
- ✓ What delegated rights can be exercised?
- ✓ What automation paths are reachable?
- ✓ What trust relationships connect this to other essential assets?

Privilege Zones Extend the Boundary-Defense Model

See where effective control crosses trust boundaries, even when traditional protections appear intact

- Privilege Zones are not replacing Tier Zero.
- They are extending the same proven logic to a more specific set of objectives.
- More closely align attack path management with how the business thinks.



Privilege Zones generalize the original BloodHound idea:
Define the boundary that matters, then understand every path that crosses into it.

We’re Already Drowning in Tier Zero Findings

That is exactly why Privilege Zones matter

- Privilege Zone Findings do not duplicate paths that already transit via Tier Zero
- They surface non-Tier Zero paths into business-critical systems
- These findings are often localized and more actionable
- Attack Path Management is a team sport
  - Privilege Zones can help distribute remediation to teams that actually own the system
- Progress is often possible even before Tier Zero is fully solved

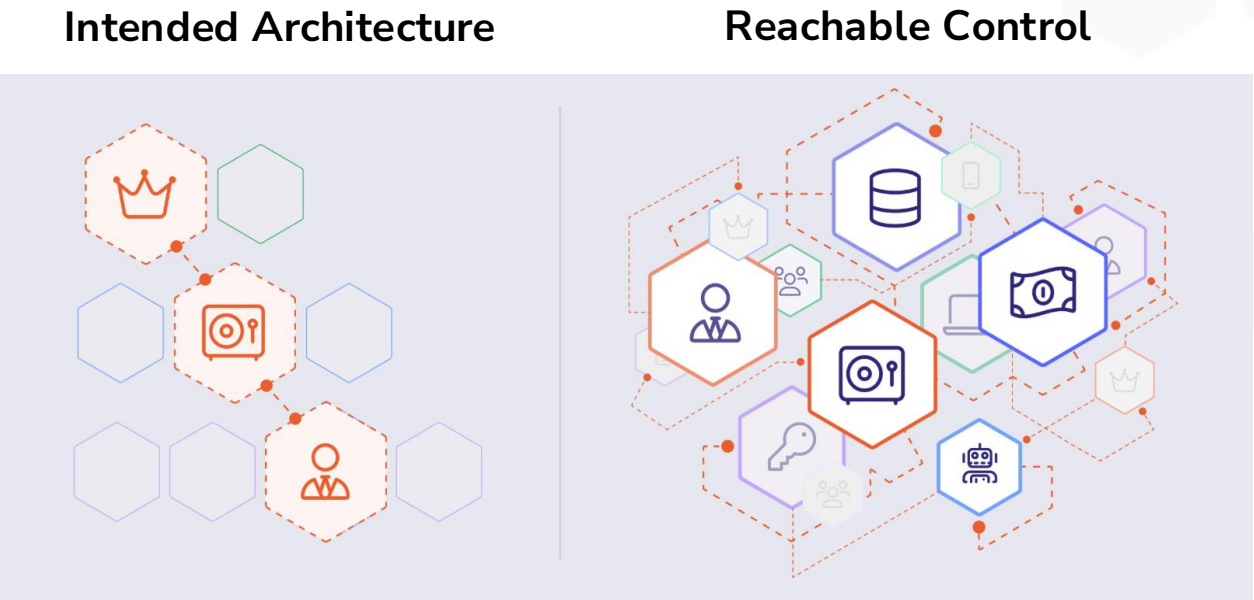
Progress does not always start by solving all of Tier Zero.
Sometimes it starts by reducing the paths that matter most.

Architecture as Imagined vs. as It Really Behaves

Why the graph rarely matches the diagram

Intended boundaries are not always real boundaries:

- Administrative access crosses intended boundaries
- Roles and permissions overlap in unexpected ways
- Service accounts accumulate hidden control
- Identity dependencies span platforms and environments



Attackers operate on reachable control, not on the diagrams we draw.

Defining Critical Assets

And treating them like Tier zero

Enclaves & Tiers

AD Tier 1 servers (EASM)

Regulatory data (HIPAA, PCI)

OT environments

Test whether these assets are truly isolated or if transitive paths through service accounts, nested group memberships, and lingering sessions create ripe attack paths.

Example: Regulated Patient Data

Critical Resources

Code repositories

DevOps build pipelines

Data warehouses and stores

Understand how attackers can reach sensitive resources without requiring Tier Zero and govern access decisions based on attack path exposure.

Example: DevOps Build

Critical Systems

ERP and EHR environments

Rewards points programs

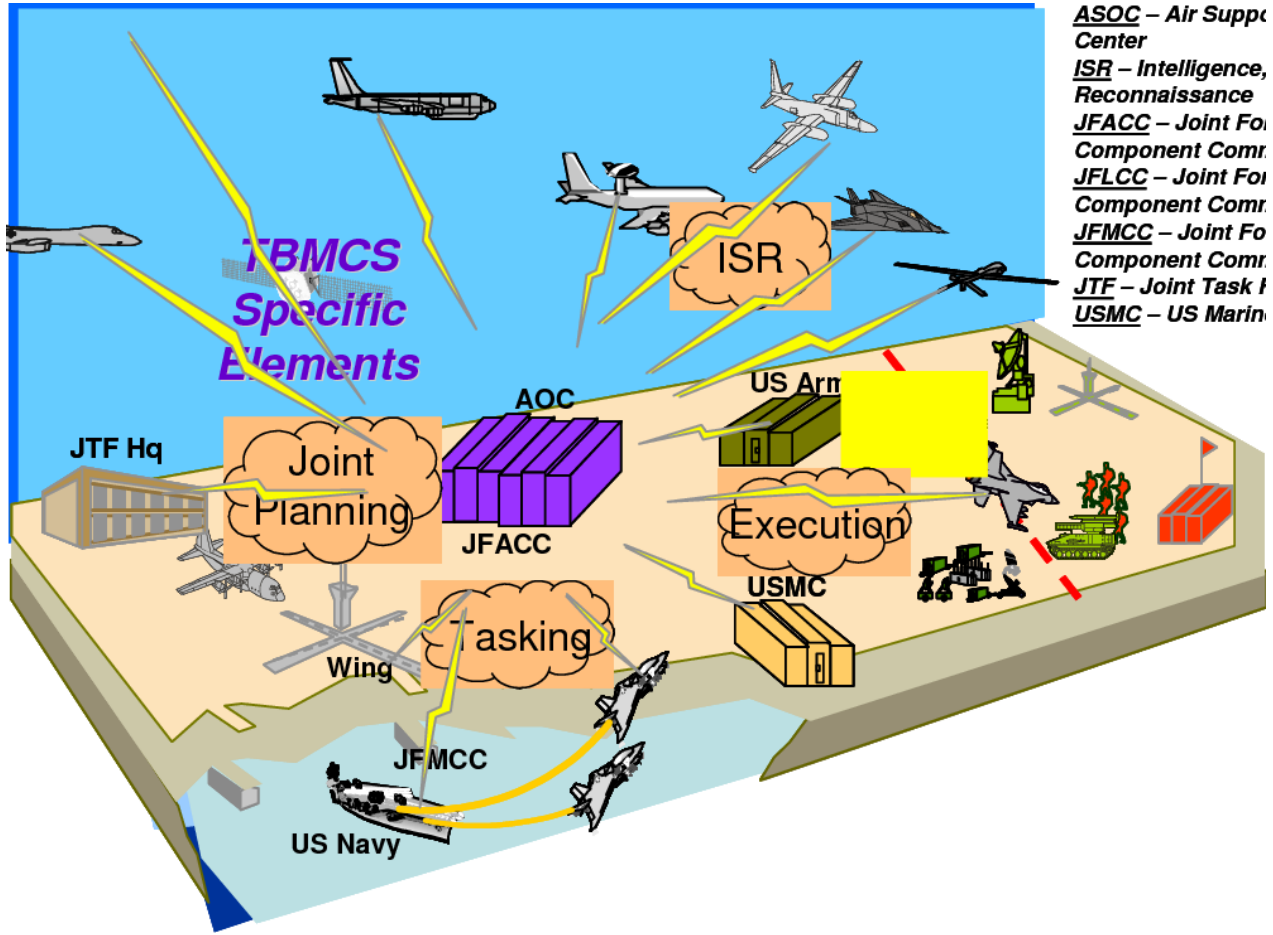
Bookings systems

Maintain uptime of key systems by understanding how a single compromised service account can disrupt operations before it happens.

Example: Financial Trading Platform

You Cannot Protect an Abstract Concept

To defend a mission system, you first must make it concrete.

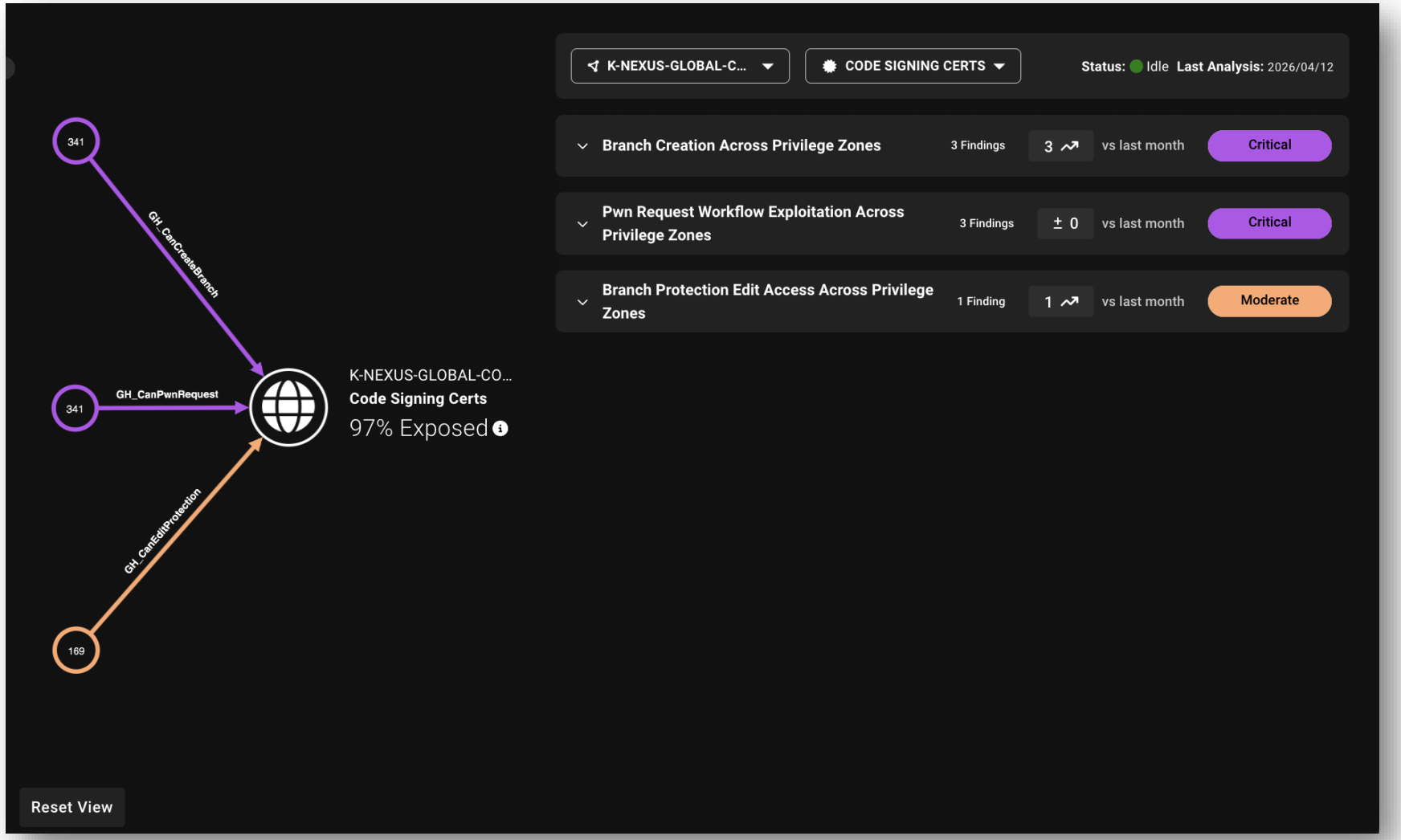


- We were tasked with protecting TBMCS, but at first TBMCS was just an abstract mission label.
- The initial diagrams explained what the system meant operationally, but not what it was technically.
- To defend it, we had to turn that abstraction into a real boundary by identifying:
  - the technical components
  - the operational workflows
  - the supporting identities
  - the dependencies between them
- Examples we discovered included:
  - legacy server infrastructure
  - operational chat as a critical dependency
  - a file share used for ATO distribution

You cannot protect a mission name. You have to understand the actual system behind it.

From Theory to Practice:
Protecting Code Signing Certificates

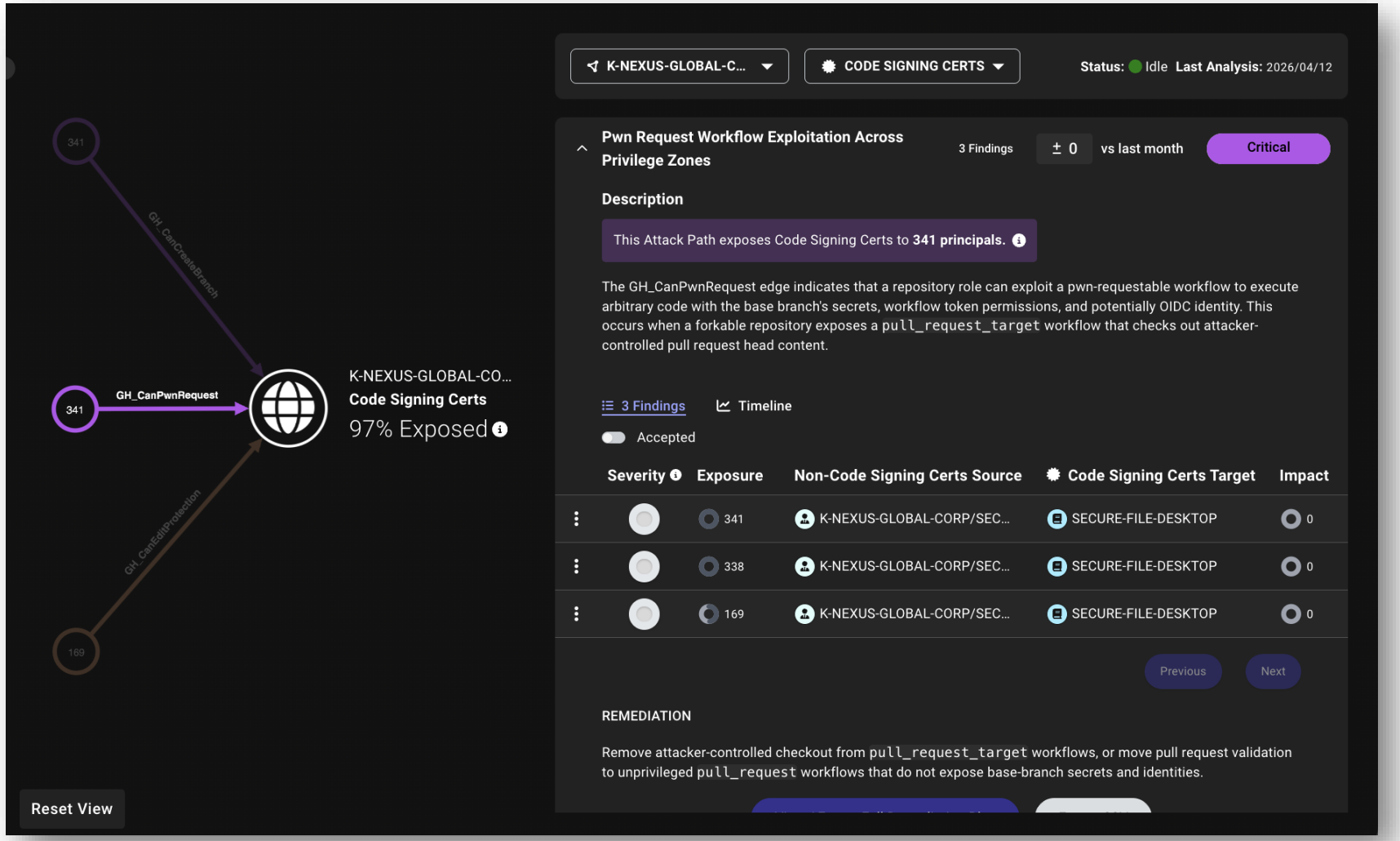
The Signing Zone is Broadly Exposed



Key Takeaways

- Zone is 97% exposed
- 3 distinct cross-zone finding types
- Exposure is measured against the zone boundary

Unsafe PR Trust Exposes the Signing Zone

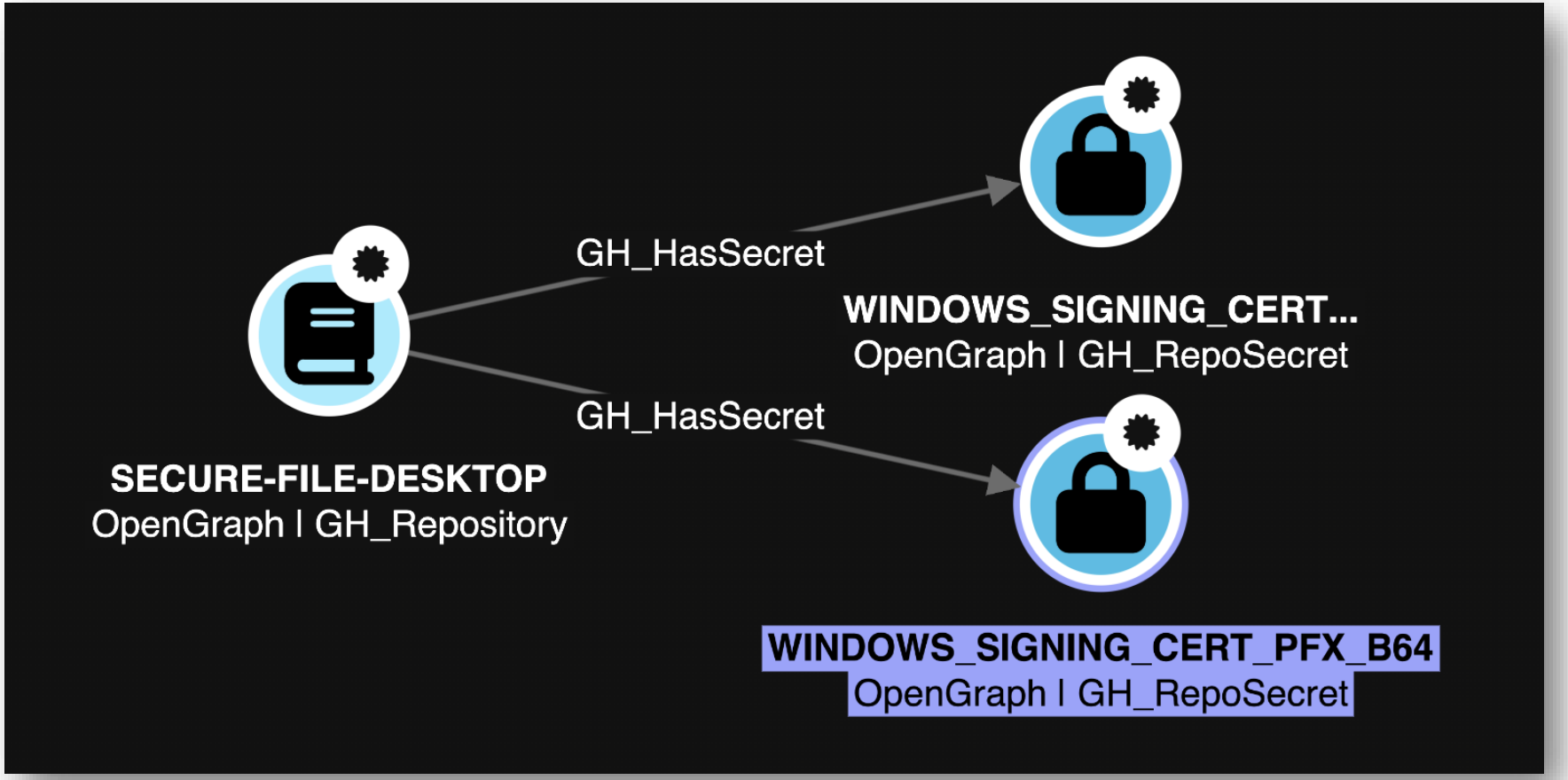


Key Takeaways

- 341 exposed principals
- Read access can become trusted automation execution
- These findings cross into the code signing zone

*PR = Pull Request

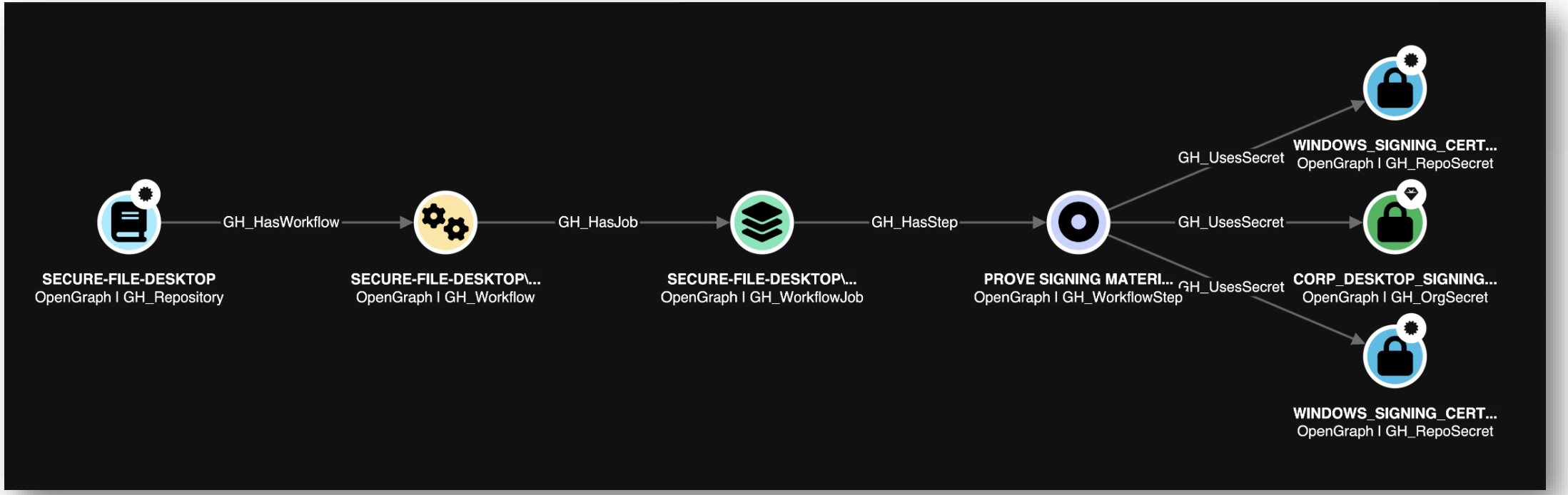
The Signing Secrets Are Scoped To The Repository



Key Takeaways

- Signing material is stored as repository secrets
- Repo scope makes the repository part of the exposure story
- Next question: does trusted automation use the secrets?

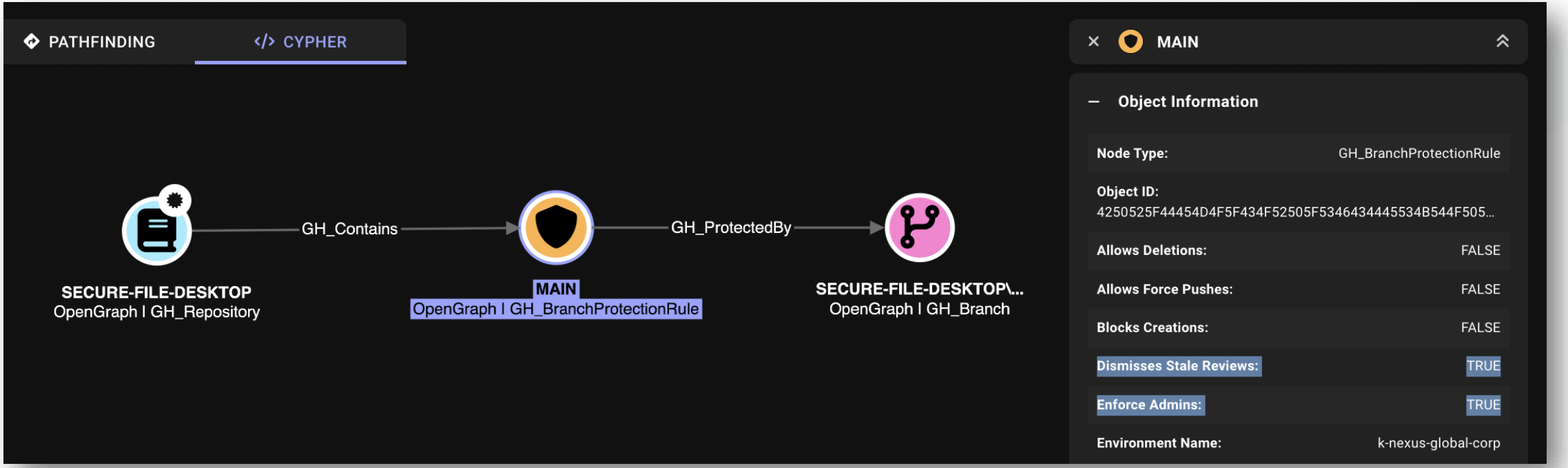
The Repository Belongs in the Signing Zone



Key Takeaways

- Trusted workflow steps consume signing material
- Repo-controlled logic is part of the trust boundary
- Control of the repo can influence signing output

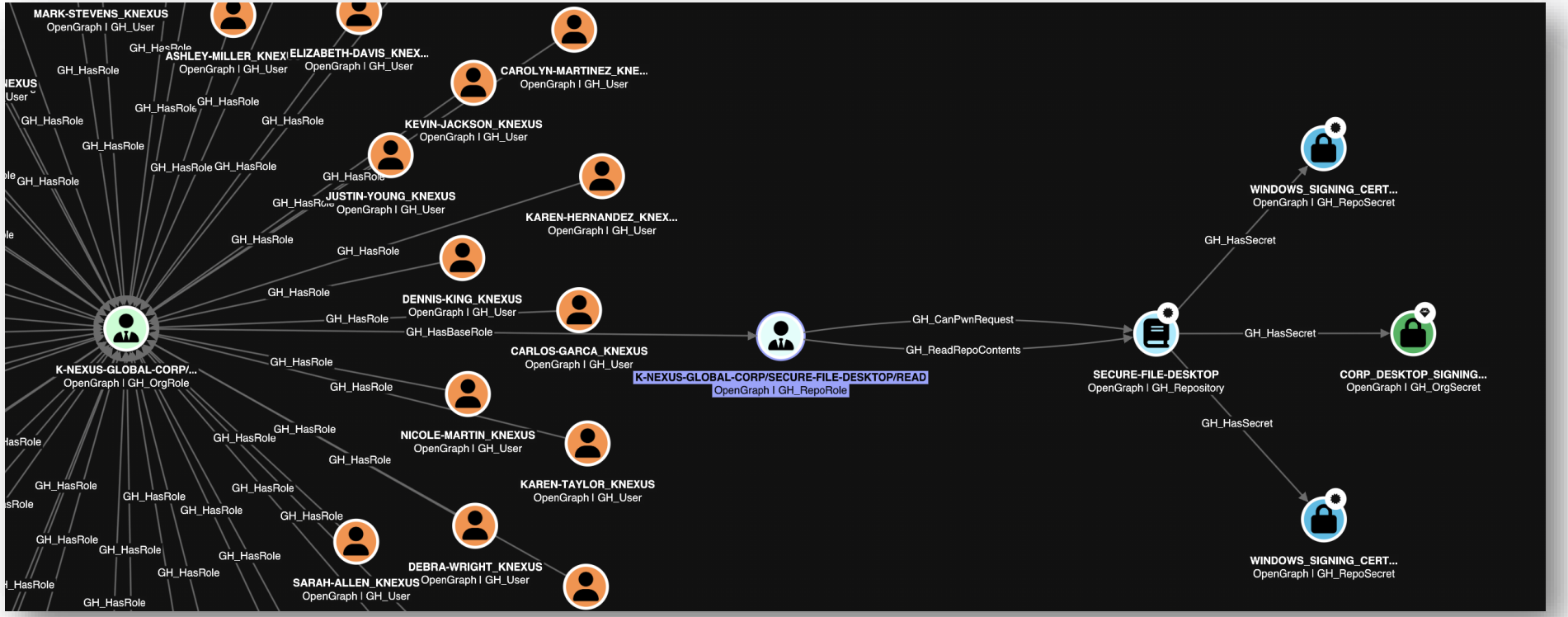
Protected Main Does Not Protect The Signing Zone



Key Takeaways

- Main is protected
- Common safeguards are in place (enforce admins)
- The signing zone is still exposed

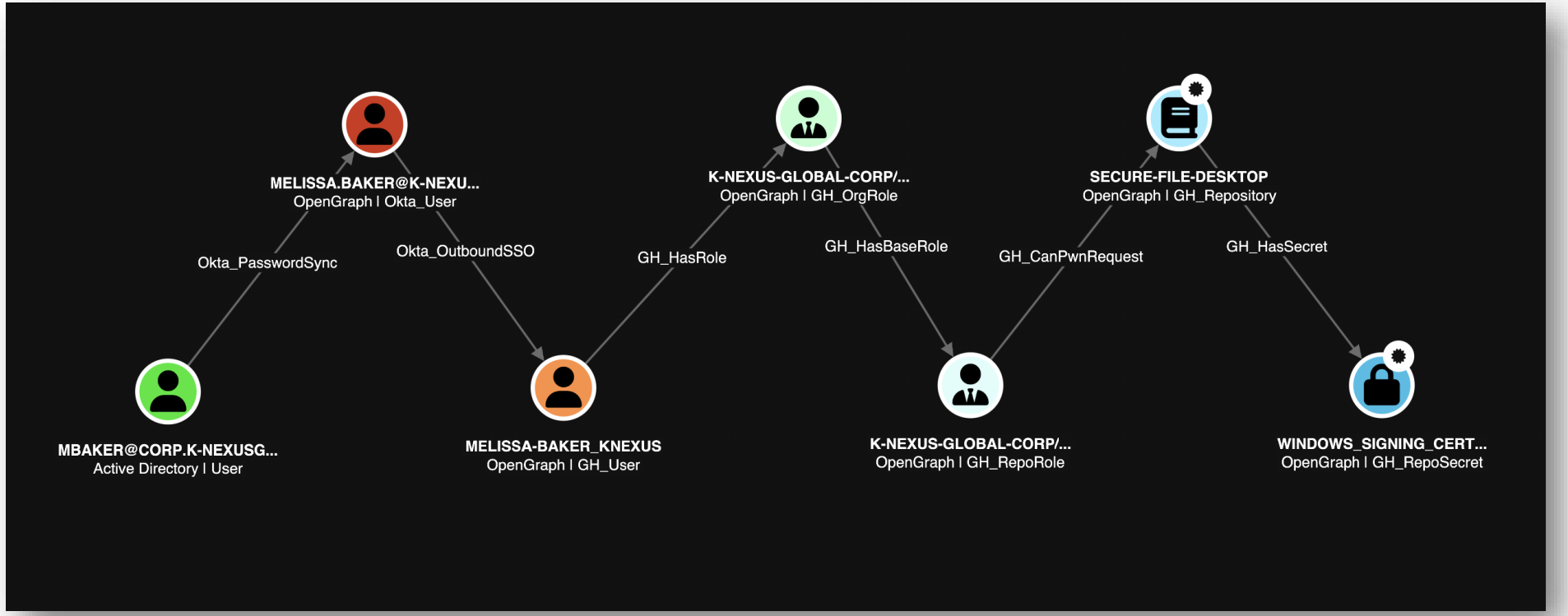
Broad Org Membership Can Escalate Into the Zone



Key Takeaways

- Org membership inherits read permission on all repos
- Read can cross into the signing zone
- This is a privilege escalation

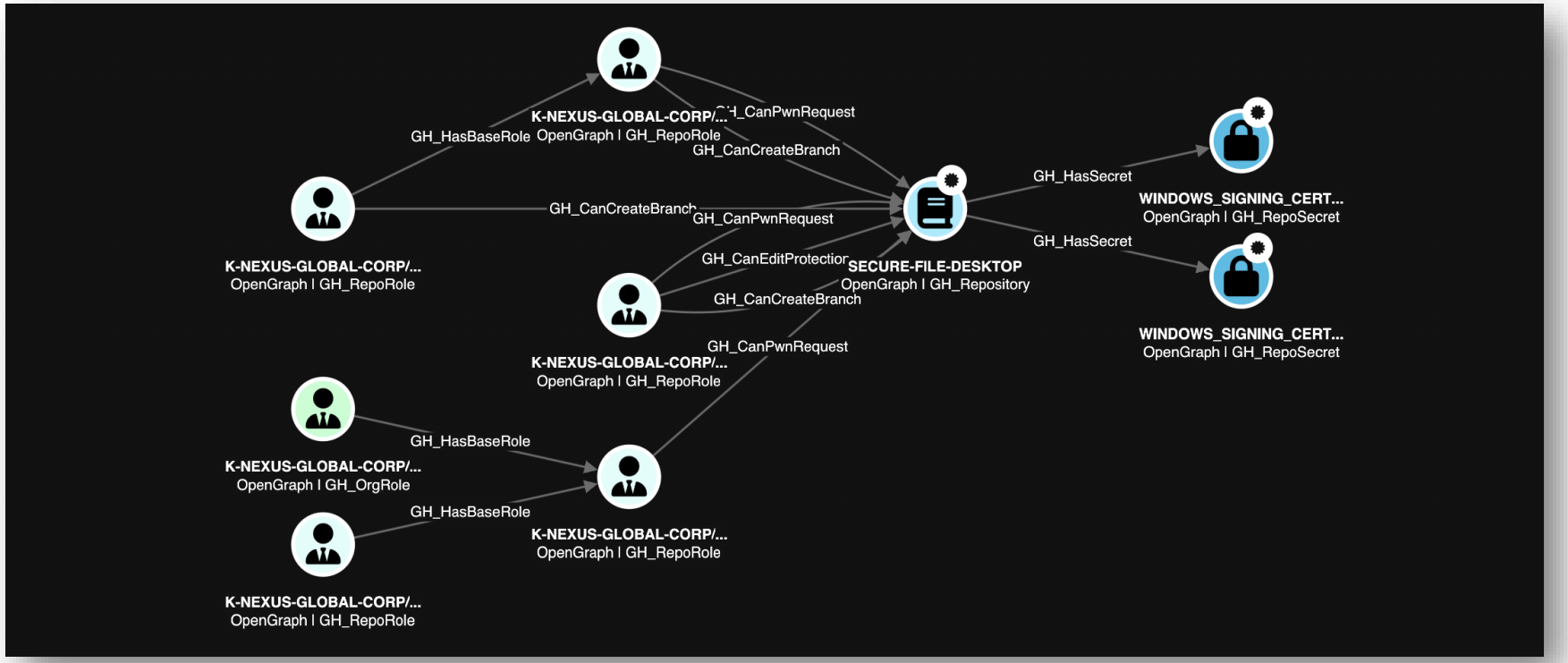
The Exposure Resolves to Real Enterprise Identities



Key Takeaways

- This is not limited to GitHub native users
- Identity relationships expand the exposed population
- Real people inherit the same path into the zone

Multiple Control Paths Coverage On The Signing Zone



Key Takeaways

- This is not limited to GitHub native users
- Identity relationships expand the exposed population
- Real people inherit the same path into the zone

What the Case Study Taught Us

- The Privilege Zone was not limited to the Secret that contained the code signing certificate
- The Secrets were defined within the scope of a Repository
  - This was shown to be desired, thus the Repository had to be included within the trust boundary
- Identity relationships expanded exposure beyond GitHub-native users
  - AD
  - Entra
  - Okta
- Privilege Zones exposed a real business trust boundary, not just a misconfiguration
  - The organization assumed that the combination of the Branch Protection Rule and the use of "Secrets" was enough to secure the values

Conclusion

From Protecting the Domain to Protecting the Business

- BloodHound Enterprise first taught defenders how to see all of the paths crossing into Tier Zero as a single boundary-defense problem.
- Tier Zero was the right place to start because it was a stable proxy for catastrophic downstream impact.
  - But modern environments are larger, more interconnected, and more dependent than they appear.
- Privilege Zones extend the same BloodHound logic to the systems, dependencies, and mission functions that actually determine business impact.
  - Attack Path Management matures when it moves from universal administrative boundaries to business-specific defended terrain.

Tier Zero helped us identify the universal problem.
Privilege Zones help us define and defend the specific terrain that matters most.